

Cryptography and Network Security

Fifth Edition
by William Stallings

Overview and Chapter1

Based on the lecture slides by Lawrie Brown for “Cryptography and Network Security”, 5/e, by William Stallings, briefly reviewing the text outline from Ch 0, and then presenting the content from Chapter 1 – “Introduction”.

Chapter 0 - Reader's Guide

The art of war teaches us to rely not on the likelihood of the enemy's not coming, but on our own readiness to receive him; not on the chance of his not attacking, but rather on the fact that we have made our position unassailable.

—The Art of War, Sun Tzu

This quote from the start of Ch0 "Reader's Guide" sets the scene for why we want to study these issues.

Roadmap

- ❑ Cryptographic algorithms
 - symmetric ciphers
 - asymmetric encryption
 - hash functions
- ❑ Mutual Trust
- ❑ Network Security
- ❑ Computer Security

The material in this book is organized into four broad categories:

- **Cryptographic algorithms:** This is the study of techniques for ensuring the secrecy and/or authenticity of information. The three main areas of study in this category are: 1. symmetric encryption, 2. asymmetric encryption, and 3. cryptographic hash functions, with the related topics of message authentication codes and digital signatures.

- **Mutual trust:** This is the study of techniques and algorithms for providing mutual trust in two main areas. First, key management and distribution deals with establishing trust in the encryption keys used between two communicating entities. Second, user authentication deals with establish trust in the identity of a communicating partner.

- **Network security:** This area covers the use of cryptographic algorithms in network protocols and network applications.

- **Computer security:** In this book, we use this term to refer to the security of computers against intruders (e.g., hackers) and malicious software (e.g., viruses). Typically, the computer to be secured is attached to a network and the bulk of the threats arise from the network.

Standards Organizations

- ❑ National Institute of Standards & Technology (NIST)
- ❑ Internet Society (ISOC)
- ❑ International Telecommunication Union
Telecommunication Standardization Sector (ITU-T)
- ❑ International Organization for Standardization (ISO)

Throughout this book, we describe the most important standards in use or being developed for various aspects of cryptography and

network security. Various organizations have been involved in the development or promotion of these standards including:

- NIST is a U.S. federal agency that deals with measurement science, standards, and technology related to U.S. government use

and to the promotion of U.S. private-sector innovation. Despite its national scope, NIST Federal Information Processing Standards (FIPS) and Special Publications (SP) have a worldwide impact.

- ISOC is a professional membership society with worldwide organizational and individual membership. It provides leadership in addressing issues that confront the future of the Internet and is the organization home for the groups responsible for Internet infrastructure standards, including the Internet Engineering Task Force (IETF) and the Internet Architecture Board (IAB). These organizations develop Internet standards and related specifications, all of which are published as Requests for Comments (RFCs).

- ITU is an international organization within the United Nations System in which governments and the private sector coordinate global telecom networks and services. The ITU Telecommunication Standardization Sector (ITU-T) is one of the three sectors of the ITU. ITU-T's mission is the production of standards covering all fields of telecommunications. ITU-T standards are referred to as Recommendations.

- ISO is a worldwide federation of national standards bodies from more than 140 countries, one from each country. ISO is a nongovernmental organization that promotes the development of standardization and related activities with a view to facilitating the international exchange of goods and services, and to developing cooperation in the spheres of intellectual, scientific, technological, and economic activity. ISO's work results in international agreements that are published as International Standards.

Chapter 1 - Introduction

- *The combination of space, time, and strength that must be considered as the basic elements of this theory of defense makes this a fairly complicated matter. Consequently, it is not easy to find a fixed point of departure..*
— ***On War, Carl Von Clausewitz***

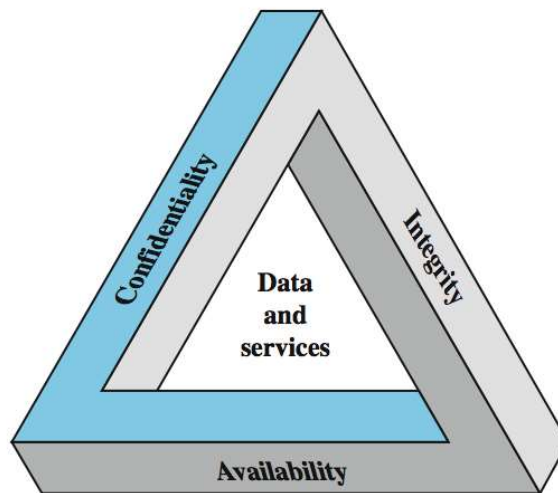
This quote from the start of Ch 1 reflects a fundamental principle that we must understand the strength of the algorithms we use in order to have a suitable level of security.

Computer Security

- the protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, availability and confidentiality of information system resources (includes hardware, software, firmware, information/data, and telecommunications)

The NIST Computer Security Handbook [NIST95] defines the term *computer security* as shown on this slide. This definition introduces three key objectives that are at the heart of computer security as we see on the next slide.

Key Security Concepts



These three concepts form what is often referred to as the **CIA triad** (Figure 1.1). The three concepts embody the fundamental security objectives for both data and for information and computing services. FIPS PUB 199 provides a useful characterization of these three objectives in terms of requirements and the definition of a loss of security in each category:

- **Confidentiality** (covers both data confidentiality and privacy): preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information. A loss of confidentiality is the unauthorized disclosure of information.
- **Integrity** (covers both data and system integrity): Guarding against improper information modification or destruction, and includes ensuring information non-repudiation and authenticity. A loss of integrity is the unauthorized modification or destruction of information.
- **Availability**: Ensuring timely and reliable access to and use of information. A loss of availability is the disruption of access to or use of information or an information system.

Although the use of the CIA triad to define security objectives is well established, some in the security field feel that additional concepts are needed to present a complete picture. Two of the most commonly mentioned are:

- **Authenticity**: The property of being genuine and being able to be verified and trusted; confidence in the validity of a transmission, a message, or message originator.
- **Accountability**: The security goal that generates the requirement for actions of an entity to be traced uniquely to that entity.

Levels of Impact

- ❑ can define 3 levels of impact from a security breach
 - Low
 - Moderate
 - High

We can define three levels of impact on organizations or individuals should there be a breach of security (i.e., a loss of confidentiality, integrity, or availability). These levels are defined in FIPS PUB 199:

- **Low:** The loss could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals. A limited adverse effect means that, for example, the loss of confidentiality, integrity, or availability might (i) cause a degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is noticeably reduced; (ii) result in minor damage to organizational assets; (iii) result in minor financial loss; or (iv) result in minor harm to individuals.
- **Moderate:** The loss could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals. A serious adverse effect means that, for example, the loss might (i) cause a significant degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is significantly reduced; (ii) result in significant damage to organizational assets; (iii) result in significant financial loss; or (iv) result in significant harm to individuals that does not involve loss of life or serious, life-threatening injuries.
- **High:** The loss could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals. A severe or catastrophic adverse effect means that, for example, the loss might (i) cause a severe degradation in or loss of mission capability to an extent and duration that the organization is not able to perform one or more of its primary functions; (ii)

result in major damage to organizational assets; (iii) result in major financial loss; or (iv) result in severe or catastrophic harm to individuals involving loss of life or serious life threatening injuries.

Examples of Security Requirements

- ❑ confidentiality - student grades
- ❑ integrity - patient information
- ❑ availability - authentication service

We now provide some examples of applications that illustrate the requirements just enumerated.

- Confidentiality - Student grade information is an asset whose confidentiality is considered to be highly important by students. Grade information should only be available to students, their parents, and employees that require the information to do their job. Student enrollment information may have a moderate confidentiality rating. While still covered by FERPA, this information is seen by more people on a daily basis, is less likely to be targeted than grade information, and results in less damage if disclosed. Directory information, such as lists of students or faculty or departmental lists, may be assigned a low confidentiality rating or indeed no rating. This information is typically freely available to the public and published on a school's Web site.

- Integrity – Consider a hospital patient's allergy information stored in a database. The doctor should be able to trust that the information is correct and current. Now suppose that an employee (e.g., a nurse) who is authorized to view and update this information deliberately falsifies the data to cause harm to the hospital. The database needs to be restored to a trusted basis quickly, and it should be possible to trace the error back to the person responsible. Patient allergy information is an example of an asset with a high requirement for integrity. Inaccurate information could result in serious harm or death to a patient and expose the hospital to massive liability.

- Availability - The more critical a component or service, the higher is the level of availability required. Consider a system that provides authentication services for

critical systems, applications, and devices. An interruption of service results in the inability for customers to access computing resources and staff to access the resources they need to perform critical tasks. The loss of the service translates into a large financial loss in lost employee productivity and potential customer loss.

Computer Security Challenges

1. not simple
2. must consider potential attacks
3. procedures used counter-intuitive
4. involve algorithms and secret info
5. must decide where to deploy mechanisms
6. battle of wits between attacker / admin
7. not perceived on benefit until fails
8. requires regular monitoring
9. too often an after-thought
10. regarded as impediment to using system

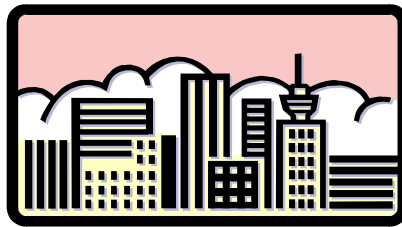
Computer security is both fascinating and complex. Some of the reasons follow:

- 1.** Computer security is not as simple as it might first appear to the novice. The requirements seem to be straightforward, but the mechanisms used to meet those requirements can be quite complex and subtle.
- 2.** In developing a particular security mechanism or algorithm, one must always consider potential attacks (often unexpected) on those security features.
- 3.** Hence procedures used to provide particular services are often counterintuitive.
- 4.** Having designed various security mechanisms, it is necessary to decide where to use them.
- 5.** Security mechanisms typically involve more than a particular algorithm or protocol, but also require participants to have secret information, leading to issues of creation, distribution, and protection of that secret information.
- 6.** Computer security is essentially a battle of wits between a perpetrator who tries to find holes and the designer or administrator who tries to close them.
- 7.** There is a natural tendency on the part of users and system managers to perceive little benefit from security investment until a security failure occurs.
- 8.** Security requires regular monitoring, difficult in today's short-term environment.
- 9.** Security is still too often an afterthought - incorporated after the design is complete.
- 10.** Many users / security administrators view strong security as an impediment to

efficient and user-friendly operation of an information system or use of information.

OSI Security Architecture

- ❑ ITU-T X.800 "Security Architecture for OSI"
- ❑ defines a systematic way of defining and providing security requirements
- ❑ for us it provides a useful, if abstract, overview of concepts we will study



To assess effectively the security needs of an organization and to evaluate and choose various security products and policies, the manager responsible for security needs some systematic way of defining the requirements for security and characterizing the approaches to satisfying those requirements. This is difficult enough in a centralized data processing environment; with the use of local and wide area networks the problems are compounded. ITU-T Recommendation X.800, *Security Architecture for OSI*, defines such a systematic approach. The OSI security architecture is useful to managers as a way of organizing the task of providing security.

Aspects of Security

- ❑ consider 3 aspects of information security:
 - security attack
 - security mechanism
 - security service
- ❑ note terms
 - *threat* - a potential for violation of security
 - *attack* - an assault on system security, a deliberate attempt to evade security services

The OSI security architecture focuses on security attacks, mechanisms, and services. These can be defined briefly as follows:

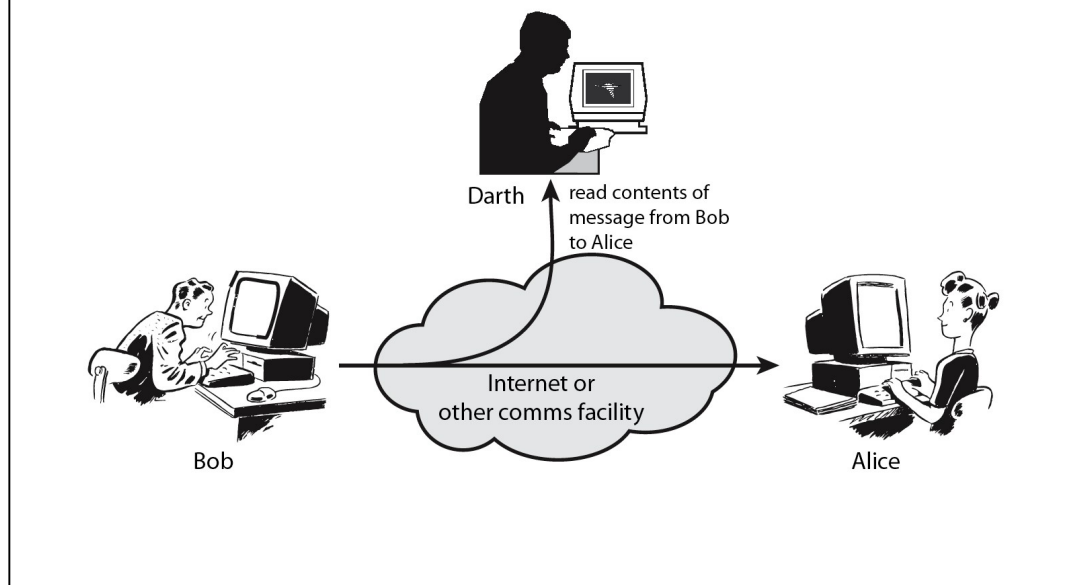
- **Security attack:** Any action that compromises the security of information owned by an organization.
- **Security mechanism:** A process (or a device incorporating such a process) that is designed to detect, prevent, or recover from a security attack.
- **Security service:** A processing or communication service that enhances the security of the data processing systems and the information transfers of an organization. The services are intended to counter security attacks, and they make use of one or more security mechanisms to provide the service.

In the literature, the terms *threat and attack* are commonly used to mean more or less the same thing. Table 1.1 provides definitions taken from RFC 2828, *Internet Security Glossary*.

Threat - A potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm. That is, a threat is a possible danger that might exploit a vulnerability.

Attack - An assault on system security that derives from an intelligent threat; that is, an intelligent act that is a deliberate attempt (especially in the sense of a method or technique) to evade security services and violate the security policy of a system.

Passive Attacks



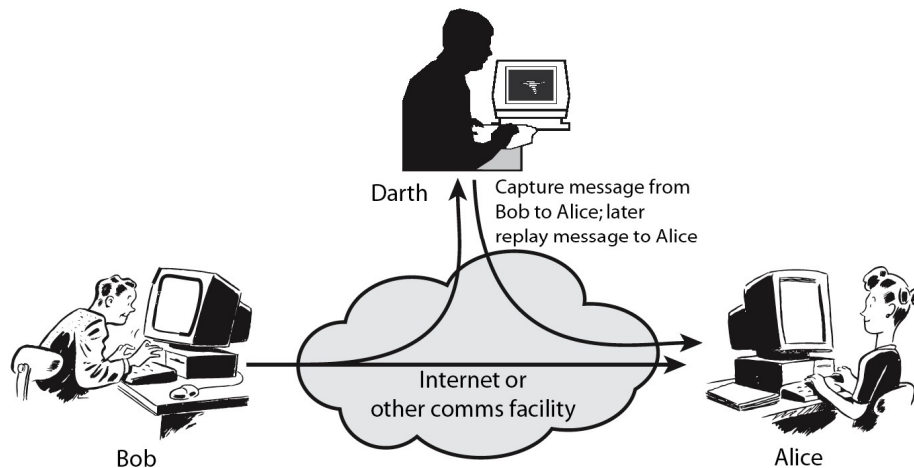
A useful means of classifying security attacks, used both in X.800 and RFC 2828, is in terms of *passive attacks* and *active attacks*. A passive attack attempts to learn or make use of information from the system but does not affect system resources.

Passive attacks are in the nature of eavesdropping on, or monitoring of, transmissions. The goal of the opponent is to obtain information that is being transmitted. Two types of passive attacks are:

- + release of message contents - as shown above in Stallings Figure 1.2a here
- + traffic analysis - monitor traffic flow to determine location and identity of communicating hosts and could observe the frequency and length of messages being exchanged

These attacks are difficult to detect because they do not involve any alteration of the data.

Active Attacks



Active attacks involve some modification of the data stream or the creation of a false stream and can be subdivided into four categories: masquerade, replay, modification of messages, and denial of service:

- masquerade of one entity as some other
- replay previous messages (as shown above in Stallings Figure 1.3b)
- modify/alter (part of) messages in transit to produce an unauthorized effect
- denial of service - prevents or inhibits the normal use or management of communications facilities

Active attacks present the opposite characteristics of passive attacks. Whereas passive attacks are difficult to detect, measures are available to prevent their success. On the other hand, it is quite difficult to prevent active attacks absolutely, because of the wide variety of potential physical, software, and network vulnerabilities. Instead, the goal is to detect active attacks and to recover from any disruption or delays caused by them.

Security Service

- Enhance security of data processing systems and information transfers of an organization
- Intended to counter security attacks
- using one or more security mechanisms
- Often replicates functions normally associated with physical documents
 - which, for example, have signatures, dates; need protection from disclosure, tampering, or destruction; be notarized or witnessed; be recorded or licensed

Consider the role of a security service, and what may be required.

Note both similarities and differences with traditional paper documents, which for example:

- have signatures & dates;
- need protection from disclosure, tampering, or destruction;
- may be notarized or witnessed;
- may be recorded or licensed

Security Services

- ❑ X.800:

"a service provided by a protocol layer of communicating open systems, which ensures adequate security of the systems or of data transfers"

- ❑ RFC 2828:

"a processing or communication service provided by a system to give a specific kind of protection to system resources"

State here a couple of definitions of "security services" from relevant standards. X.800 defines a security service as a service provided by a protocol layer of communicating open systems, which ensures adequate security of the systems or of data transfers. Perhaps a clearer definition is found in RFC 2828, which provides the following definition: a processing or communication service that is provided by a system to give a specific kind of protection to system resources; security services implement security policies and are implemented by security mechanisms.

Security Services (X.800)

- ❑ **Authentication** - assurance that communicating entity is the one claimed
 - have both peer-entity & data origin authentication
- ❑ **Access Control** - prevention of the unauthorized use of a resource
- ❑ **Data Confidentiality** - protection of data from unauthorized disclosure
- ❑ **Data Integrity** - assurance that data received is as sent by an authorized entity
- ❑ **Non-Repudiation** - protection against denial by one of the parties in a communication
- ❑ **Availability** - resource accessible/usable

This list is taken from Stallings Table 1.2 which provides details of the 5 Security Service categories and the 14 specific services given in X.800.

This list includes the various "classic" security services which are traditionally discussed. Note there is a degree of ambiguity as to the meaning of these terms, and overlap in their use. The broad service categories are:

•**authentication** is concerned with assuring that a communication is authentic.

Two specific authentication services are defined in X.800: **Peer entity authentication**: provides corroboration of the identity of a peer entity in an association; and **Data origin authentication**: provides corroboration of the source of a data unit.

•**access control** is the ability to limit and control the access to host systems and applications via communications links.

•**confidentiality** is the protection of transmitted data from passive attacks, and the protection of traffic flow from analysis.

•**integrity** assures that messages are received as sent, with no duplication, insertion, modification, reordering, replay, or loss.

•**availability** is the property of a system / resource being accessible and usable upon demand by an authorized system entity, according to performance specifications for the system.

Security Mechanism

- ❑ feature designed to detect, prevent, or recover from a security attack
- ❑ no single mechanism that will support all services required
- ❑ however one particular element underlies many of the security mechanisms in use:
 - **cryptographic techniques**
- ❑ hence our focus on this topic

Now introduce “Security Mechanism” which are the specific means of implementing one or more security services. Note these mechanisms span a wide range of technical components, but one aspect seen in many is the use of cryptographic techniques.

Security Mechanisms (X.800)

□ specific security mechanisms:

- encipherment, digital signatures, access controls, data integrity, authentication exchange, traffic padding, routing control, notarization

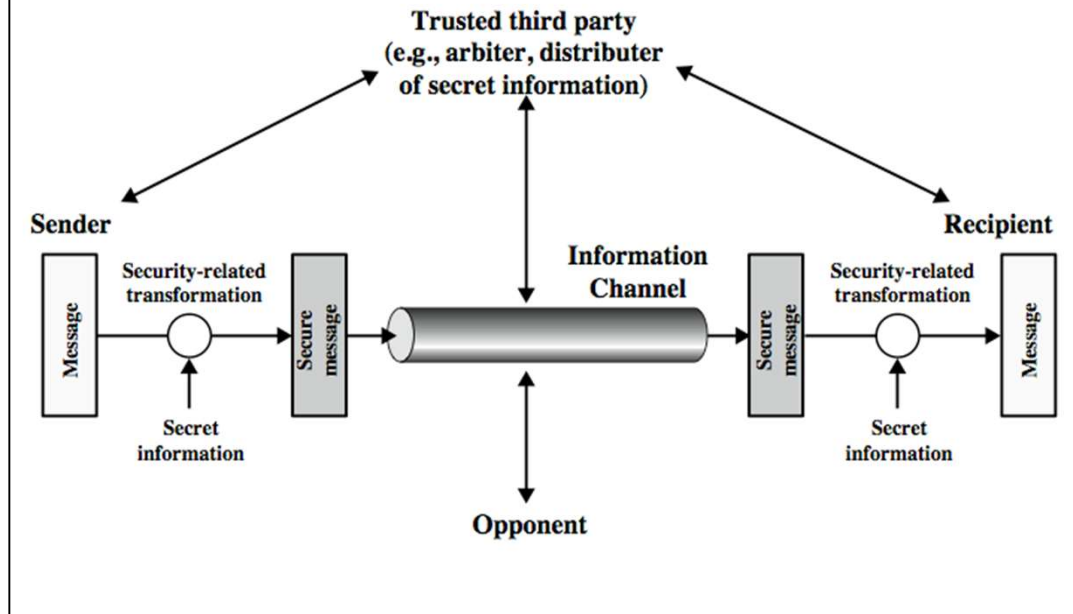
□ pervasive security mechanisms:

- trusted functionality, security labels, event detection, security audit trails, security recovery

Some examples of mechanisms from X.800. Note that the “specific security mechanisms” are protocol layer specific, whilst the “pervasive security mechanisms” are not. We will meet some of these mechanisms in much greater detail later.

See Stallings Table 1.3 for details of these mechanisms in X.800, and Table 1.4 for the relationship between services and mechanisms.

Model for Network Security



In considering the place of encryption, it's useful to use the following two models from Stallings section 1.6.

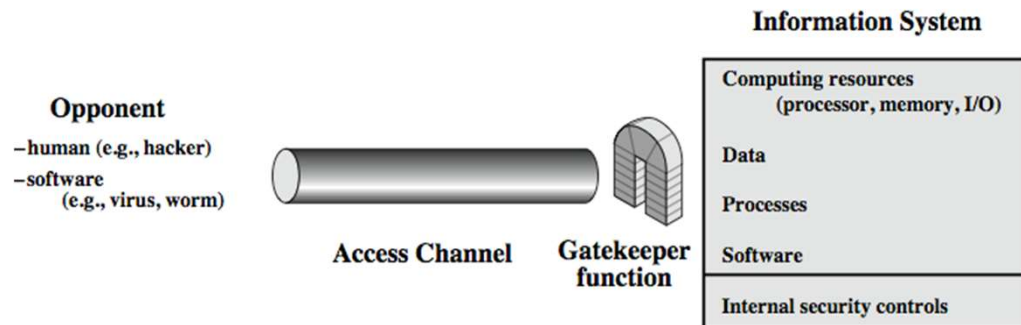
The first, illustrated in Figure 1.4, models information being transferred from one party to another over an insecure communications channel, in the presence of possible opponents. The two parties, who are the principals in this transaction, must cooperate for the exchange to take place. They can use an appropriate **security transform (encryption algorithm)**, with suitable **keys**, possibly negotiated using the presence of a **trusted third party**. Parts One through Four of this book concentrate on the types of security mechanisms and services that fit into the model shown here.

Model for Network Security

- using this model requires us to:
 1. design a suitable algorithm for the security transformation
 2. generate the secret information (keys) used by the algorithm
 3. develop methods to distribute and share the secret information
 4. specify a protocol enabling the principals to use the transformation and secret information for a security service

This general model shows that there are four basic tasks in designing a particular security service, as listed.

Model for Network Access Security



The second, illustrated in Figure 1.5, model is concerned with controlled access to information or resources on a computer system, in the presence of possible opponents. Here appropriate controls are needed on the access to and within the system, to provide suitable security.

The security mechanisms needed to cope with unwanted access fall into two broad categories (as shown in this figure). The first category might be termed a gatekeeper function. It includes password-based login procedures that are designed to deny access to all but authorized users and screening logic that is designed to detect and reject worms, viruses, and other similar attacks. Once either an unwanted user or unwanted software gains access, the second line of defense consists of a variety of internal controls that monitor activity and analyze stored information in an attempt to detect the presence of unwanted intruders. These issues are explored in Part Four.

Model for Network Access Security

- using this model requires us to:
 1. select appropriate gatekeeper functions to identify users
 2. implement security controls to ensure only authorised users access designated information or resources

Detail here the tasks needed to use this model.

Summary

- ❑ topic roadmap & standards organizations
- ❑ security concepts:
 - confidentiality, integrity, availability
- ❑ X.800 security architecture
- ❑ security attacks, services, mechanisms
- ❑ models for network (access) security

Chapter 1 summary.